Chapter 9 – Cloud Security

Contents

Computer security in the new millennium

- In an interconnected world, various embodiments of malware can migrate easily from one system to another, cross national borders and infect systems all over the globe.
- The security of computing and communication systems takes a new urgency as the society becomes increasingly more dependent on the information infrastructure. Even the critical infrastructure of a nation can be attacked by exploiting flaws in computer security.
- Recently, the term <u>cyberwarfare</u> has enter the dictionary meaning "actions by a nation-state to penetrate another nation's computers or networks for the purposes of causing damage or disruption"

Cloud security

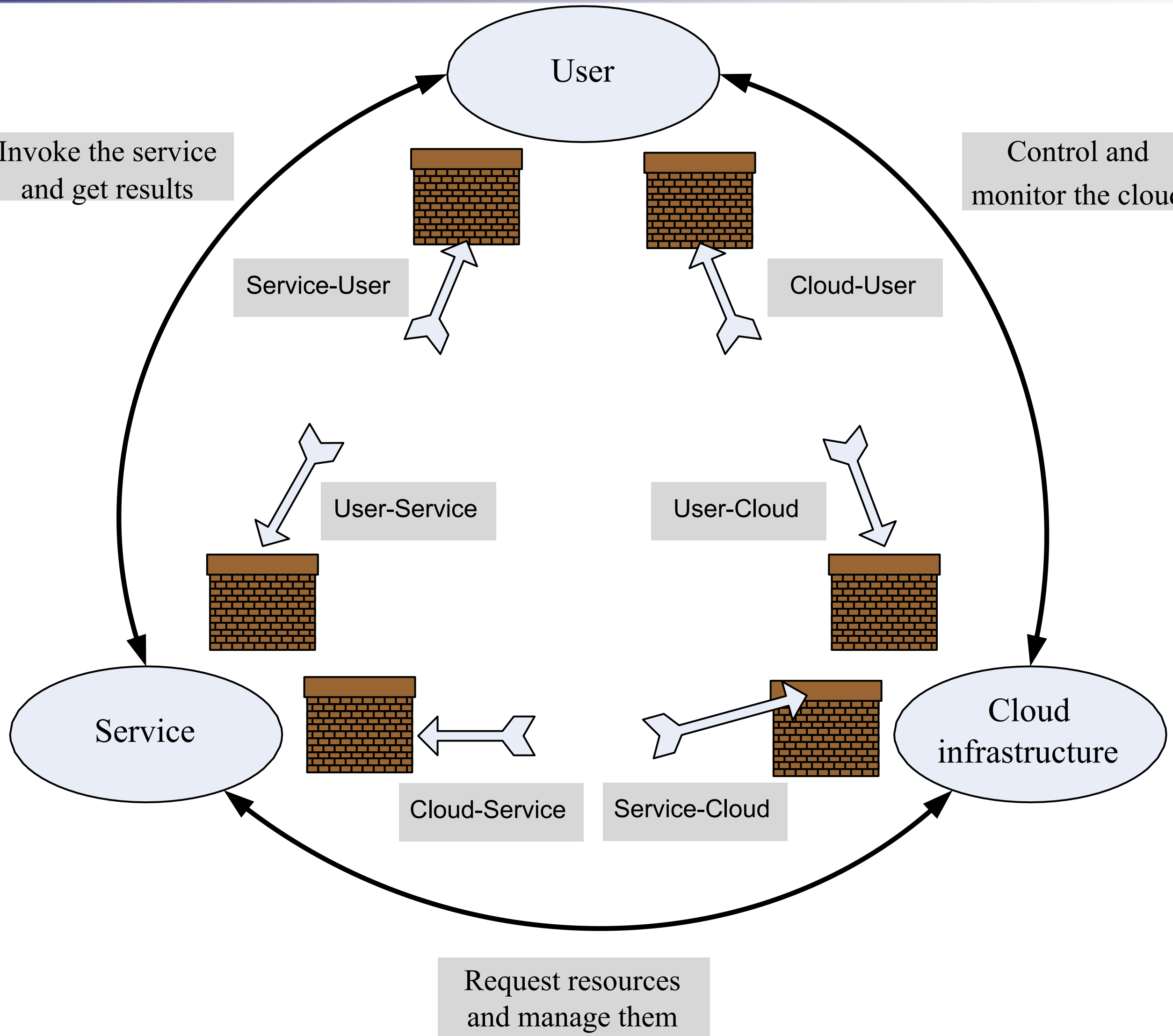
- A computer cloud is a target-rich environment for malicious individuals and criminal organizations.
- Major concern for existing users and for potential new users of cloud computing services. Outsourcing computing to a cloud generates new security and privacy concerns.
- Standards, regulations, and laws governing the activities of organizations supporting cloud computing have yet to be adopted. Many issues related to privacy, security, and trust in cloud computing are far from being settled.
- There is the need for international regulations adopted by the countries where data centers of cloud computing providers are located.
- Service Level Agreements (SLAs) do not provide adequate legal protection for cloud computer users, often left to deal with events beyond their control.

Cloud security risks

- Traditional threats impact amplified due to the vast amount of cloud resources and the large user population that can be affected. The fuzzy bounds of responsibility between the providers of cloud services and users and the difficulties to accurately identify the cause.
- New threats cloud servers host multiple VMs; multiple applications may run under each VM. Multi-tenancy and VMM vulnerabilities open new attack channels for malicious users. Identifying the path followed by an attacker more difficult in a cloud environment.
- Authentication and authorization the procedures in place for one individual does not extend to an enterprise.
- Third-party control generates a spectrum of concerns caused by the lack of transparency and limited user control.
- Availability of cloud services system failures, power outages, and other catastrophic events could shutdown services for extended periods of time.

Attacks in a cloud computing environment

- Three actors involved; six types of attacks possible.
  - The user can be attacked by:
    - Service SSL certificate spoofing, attacks on browser caches, or phishing attacks.
    - The cloud infrastructure attacks that either originates at the cloud or spoofs to originate from the cloud infrastructure.
  - The service can be attacked by:
    - A user buffer overflow, SQL injection, and privilege escalation are the common types of attacks.
    - The cloud infrastructure the most serious line of attack. Limiting access to resources, privilege-related attacks, data distortion, injecting additional operations.
  - The cloud infrastructure can be attacked by:
    - A user targets the cloud control system.
    - A service requesting an excessive amount of resources and causing the exhaustion of the resources.



Surfaces of attacks in a cloud computing environment.

Top threats to cloud computing

- Identified by a 2010 Cloud Security Alliance (CSA) report:
  - The abusive use of the cloud - the ability to conduct nefarious activities from the cloud.
  - APIs that are not fully secure - may not protect the users during a range of activities starting with authentication and access control to monitoring and control of the application during runtime.
  - Malicious insiders - cloud service providers do not disclose their hiring standards and policies, so this can be a serious threat.
  - Shared technology.
  - Account hijacking.
  - Data loss or leakage - if the only copy of the data is stored on the cloud, then sensitive data is permanently lost when cloud data replication fails followed by a storage media failure.
  - Unknown risk profile - exposure to the ignorance or underestimation of the risks of cloud computing.

Auditability of cloud activities

- The lack of transparency makes auditability a very difficult proposition for cloud computing.
- Auditing guidelines elaborated by the National Institute of Standards (NIST) are mandatory for US Government agencies:
  - the Federal Information Processing Standard (FIPS).
  - the Federal Information Security Management Act (FISMA).

Security - the top concern for cloud users

- The unauthorized access to confidential information and the data theft top the list of user concerns.
  - Data is more vulnerable in storage, as it is kept in storage for extended periods of time.
  - Threats during processing cannot be ignored; such threats can originate from flaws in the VMM, rogue VMs, or a VMBR.
- There is the risk of unauthorized access and data theft posed by rogue employees of a Cloud Service Provider (CSP).
- Lack of standardization is also a major concern.
- Users are concerned about the legal framework for enforcing cloud computing security.
- Multi-tenancy is the root cause of many user concerns. Nevertheless, multi-tenancy enables a higher server utilization, thus lower costs.
- The threats caused by multi-tenancy differ from one cloud delivery model to another.

Legal protection of cloud users

- The contract between the user and the Cloud Service Provider (CSP) should spell out explicitly:
  - CSP obligations to handle securely sensitive information and its obligation to comply to privacy laws.
  - CSP liabilities for mishandling sensitive information.
  - CSP liabilities for data loss.
  - The rules governing ownership of the data.
  - The geographical regions where information and backups can be stored.

Privacy

- Privacy the right of an individual, a group of individuals, or an organization to keep information of personal nature or proprietary information from being disclosed.
- Privacy is protected by law; sometimes laws limit privacy.
- The main aspects of privacy are: the lack of user control, potential unauthorized secondary use, data proliferation, and dynamic provisioning.
- Digital age has confronted legislators with significant challenges related to privacy as new threats have emerged. For example, personal information voluntarily shared, but stolen from sites granted access to it or misused can lead to identity theft.
- Privacy concerns are different for the three cloud delivery models and also depend on the actual context.

Federal Trading Commission Rules

- Web sites that collect personal identifying information from or about consumers online required to comply with four fair information practices:
  - Notice - provide consumers clear and conspicuous notice of their information practices, including what information they collect, how they collect it, how they use it, how they provide Choice, Access, and Security to consumers, whether they disclose the information collected to other entities, and whether other entities are collecting information through the site.
  - Choice - offer consumers choices as to how their personal identifying information is used.Such choice would encompass both internal secondary uses (such as marketing back to consumers) and external secondary uses (such as disclosing data to other entities).
  - Access - offer consumers reasonable access to the information a web site has collected about them, including a reasonable opportunity to review information and to correct inaccuracies or delete information.
  - Security - take reasonable steps to protect the security of the information they collect from consumers.

Privacy Impact Assessment (PIA)

- The need for tools capable to identify privacy issues in information systems.
- There are no international standards for such a process, though different countries and organization require PIA reports.
- The centerpiece of A proposed PIA tool is based on a SaaS service.
  - The users of the SaaS service providing access to the PIA tool must fill in a questionnaire.
  - The system used a knowledge base (KB) created and maintained by domain experts.
  - The system uses templates to generate additional questions necessary and to fill in the PIA report.
  - An expert system infers which rules are satisfied by the facts in the database and provided by the users and executes the rule with the highest priority.

Trust

- Trust assured reliance on the character, ability, strength, or truth of someone or something.
- Complex phenomena: enable cooperative behavior, promote adaptive organizational forms, reduce harmful conflict, decrease transaction costs, promote effective responses to crisis.
- Two conditions must exist for trust to develop.
  - Risk the perceived probability of loss; trust not necessary if there is no risk involved, if there is a certainty that an action can succeed.
  - Interdependence the interests of one entity cannot be archived without reliance on other entities.
- A trust relationship goes though three phases:
  1. Building phase, when trust is formed.
  2. Stability phase, when trust exists.
  3. Dissolution phase, when trust declines.
- An entity must work very hard to build trust, but may lose the trust very easily.

Internet trust

- Obscures or lacks entirely the dimensions of character and personality, nature of relationship, and institutional character of the traditional trust.
- Offers individuals the ability to obscure or conceal their identity. The anonymity reduces the cues normally used in judgments of trust.
- Identity is critical for developing trust relations, it allows us to base our trust on the past history of interactions with an entity. Anonymity causes mistrust because identity is associated with accountability and in absence of identity accountability cannot be enforced.
- The opacity extends identity to personal characteristics. It is impossible to infer if the entity or individual we transact with is who it pretends to be, as the transactions occur between entities separated in time and distance.
- There are no guarantees that the entities we transact with fully understand the role they have assumed.

How to determine trust

- Policies and reputation are two ways of determining trust.
  - Policies reveal the conditions to obtain trust, and the actions when some of the conditions are met. Policies require the verification of credentials; credentials are issued by a trusted authority and describe the qualities of the entity using the credential.
  - Reputation is a quality attributed to an entity based on a relatively long history of interactions or possibly observations of the entity. Recommendations are based on trust decisions made by others and filtered through the perspective of the entity assessing the trust.
- In a computer science context : trust of a party A to a party B for a service X is the measurable belief of A in that B behaves dependably for a specified period within a specified context (in relation to service X).

Operating system security

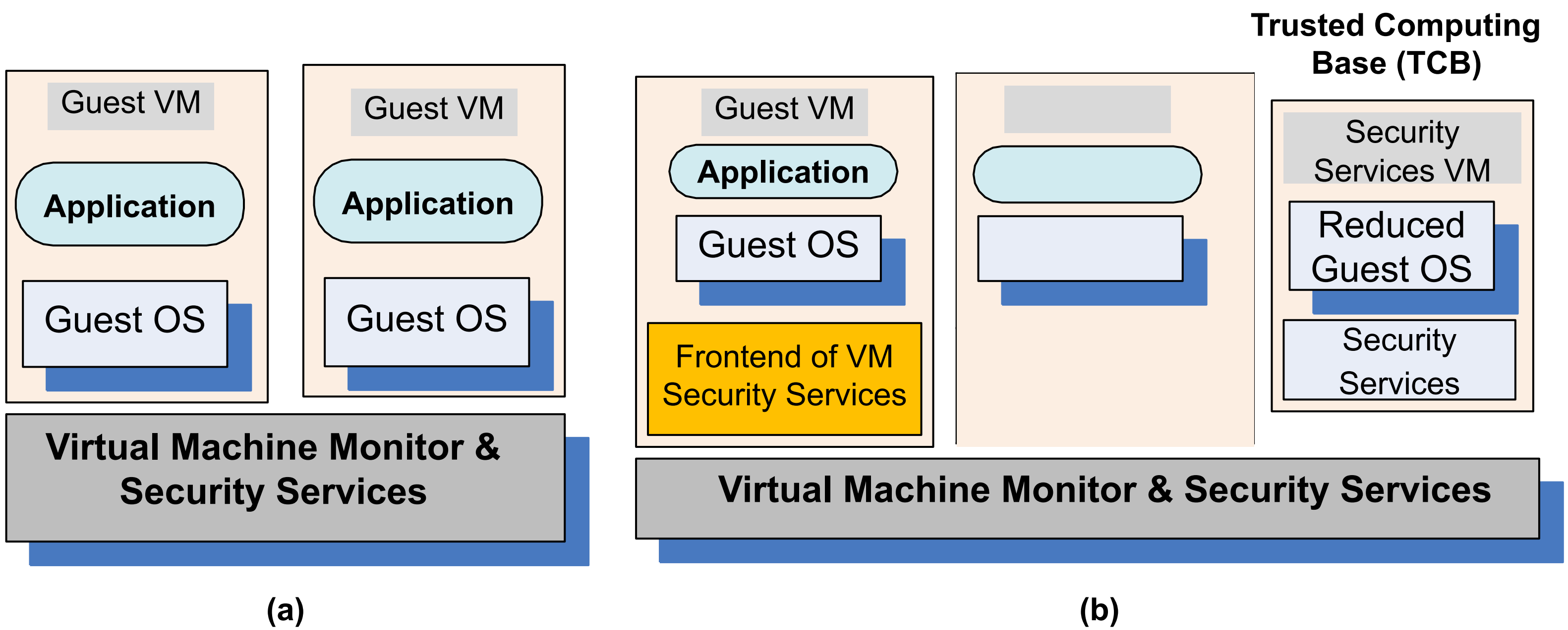
- A critical function of an OS is to protect applications against a wide range of malicious attacks, e.g., unauthorized access to privileged information, tempering with executable code, and spoofing.
- The elements of the mandatory OS security:
  - Access control mechanisms to control the access to system objects.
  - Authentication usage mechanisms to authenticate a principal.
  - Cryptographic usage policies mechanisms used to protect the data
- Commercial OS do not support a multi-layered security; only distinguish between a completely privileged security domain and a completely unprivileged one.
- Trusted paths mechanisms support user interactions with trusted software. Critical for system security; if such mechanisms do not exist, then malicious software can impersonate trusted software. Some systems provide trust paths for a few functions, such as login authentication and password changing, and allow servers to authenticate their clients.

Closed-box versus open-box platforms

- Closed-box platforms , e.g., cellular phones, game consoles and ATM could have embedded cryptographic keys to reveal their true identity to remote systems and authenticate the software running on them.
- Such facilities are not available to open-box platforms, the traditional hardware for commodity operating systems.
- Commodity operating system offer low assurance. An OS is a complex software system consisting of millions of lines of code and it is vulnerable to a wide range of malicious attacks.
- An OS provides weak mechanisms for applications to authenticate to one another and create a trusted path between users and applications.
- An OS poorly isolates one application from another; once an application is compromised, the entire physical platform and all applications running on it can be affected. The platform security level is reduced to the security level of the most vulnerable application running on the platform.

Virtual machine security

- Hybrid and hosted VMs, expose the entire system to the vulnerability of the host OS.
- In a traditional VM the Virtual Machine Monitor (VMM) controls the access to the hardware and provides a stricter isolation of VMs from one another than the isolation of processes in a traditional OS.
  - A VMM controls the execution of privileged operations and can enforce memory isolation as well as disk and network access.
  - The VMMs are considerably less complex and better structured than traditional operating systems thus, in a better position to respond to security attacks.
  - A major challenge a VMM sees only raw data regarding the state of a guest operating system while security services typically operate at a higher logical level, e.g., at the level of a file rather than a disk block.
- A secure TCB (Trusted Computing Base) is a necessary condition for security in a virtual machine environment; if the TCB is compromised then the security of the entire system is affected.



(a) Virtual security services provided by the VMM; (b) A dedicated security VM.

VMM-based threats

- Starvation of resources and denial of service for some VMs. Probable causes:
  - (a) badly configured resource limits for some VMs.
  - (b) a rogue VM with the capability to bypass resource limits set in VMM.
- VM side-channel attacks: malicious attack on one or more VMs by a rogue VM under the same VMM. Probable causes:
  - (a) lack of proper isolation of inter-VM traffic due to misconfiguration of the virtual network residing in the VMM.
  - (b) limitation of packet inspection devices to handle high speed traffic, e.g., video traffic.
  - (c) presence of VM instances built from insecure VM images, e.g., a VM image having a guest OS without the latest patches.
- Buffer overflow attacks.

VM-based threats

- Deployment of rogue or insecure VM. Unauthorized users may create insecure instances from images or may perform unauthorized administrative actions on existing VMs.
  Probable cause:
  - improper configuration of access controls on VM administrative tasks such as instance creation, launching, suspension, re-activation and so on.
- Presence of insecure and tampered VM images in the VM image repository. Probable causes:
  - (a) lack of access control to the VM image repository.
  - (b) lack of mechanisms to verify the integrity of the images, e.g., digitally signed image.